

Report di Analisi Incidente: Log di Autenticazione SSH

Data: 9 settembre 2026
Analista: NetRunners BW3
Ambiente: Splunk Enterprise 10.4.2
Dataset: `tutorialdata.zip`

1. Obiettivo dell'Analisi

Analizzare i log di autenticazione SSH per identificare tentativi di accesso non autorizzati, attacchi brute force e eventuali compromissioni del sistema.

2. Metodologia

Sono state eseguite 5 query Splunk sul dataset di log di autenticazione. `rex` è stato consigliato di usare per l'esercizio

<code>index=...</code>	"Dove cerco?" Indica il "cassetto" dei dati.	<code>index=esercizio</code> (Apri il cassetto "esercizio")
<code>"testo"</code>	"Cosa cerco?" Cerca quella frase esatta dentro i log.	<code>"Failed password"</code> (Trova le righe con questa frase)

	"E poi?" È la barra verticale. Separa i passaggi.	<pre>... table ...</pre> (Prima cerca, e poi fai una tabella)
rex	"Estrai" Prende un pezzo di testo e lo trasforma in colonna.	<pre>rex "from (?<ip>...)"</pre> (Prendi l'IP dal testo)
table	"Mostra" Scegle quali colonne mostrare.	<pre>table _time, user</pre> (Mostra solo Tempo e Utente)
stats	"Conta" Conta gli eventi e raggruppa.	<pre>stats count by ip</pre> (Conta quanti IP diversi ci sono)
where	"Filtra" Tiene solo quello che rispetta una regola.	<pre>where count > 5</pre> (Tieni solo quelli con più di 5)
sort	"Ordina" Mette in ordine i risultati.	<pre>sort -_time</pre> (Ordina dal più recente al più vecchio)
rename	"Rinomina" Cambia il nome alle colonne per renderle leggibili.	<pre>rename _time as "Data"</pre> (Cambia "_time" in "Data")

Query 1: Tentativi di accesso falliti

```
index=esercizio "Failed password"
| rex "from (?<ip>[0-9]+\.[0-9]+\.[0-9]+\.[0-9]+)"
| rex "Failed password for (?:invalid user
)?(?<user>[a-zA-Z0-9_-]+)"
| table _time, ip, user, _raw
| rename _time as "Timestamp", ip as "IP Sorgente", user as
"Username", _raw as "Motivo"
| sort -_time
```

New Search Save As Create Table View Close

```
index=esercizio "Failed password"
| rex "from (?<ip>[0-9]+\.[0-9]+\.[0-9]+\.[0-9]+)"
| rex "Failed password for (?:invalid user )?(?<user>[a-zA-Z0-9_-]+)"
| table _time, ip, user, _raw
| rename _time as "Timestamp", ip as "IP Sorgente", user as "Username", _raw as "Motivo"
| sort -_time
```

Time range: All time Q +

✓ 33,253 events (before 9/9/26 3:48:41.000 PM) No Event Sampling Job II ■ → 🖨 ↓ 💡 Smart Mode

Events Patterns **Statistics (10,000)** Visualization

Show: 20 Per Page Format Preview: On < Prev 1 2 3 4 5 6 7 8 ... Next >

Timestamp	IP Sorgente	Username	Motivo
1787433575	123.30.108.208	jabber	Tue Aug 22 2026 23:19:35 www3 sshd[4732]: Failed password for invalid user jabber from 123.30.108.208 port 1454 ssh2
1787433575	123.30.108.208	mailman	Tue Aug 22 2026 23:19:35 www3 sshd[4875]: Failed password for invalid user mailman from 123.30.108.208 port 4980 ssh2
1787433575	123.30.108.208	henri	Tue Aug 22 2026 23:19:35 www3 sshd[1664]: Failed password for invalid user henri from 123.30.108.208 port 2359 ssh2
1787433575	123.30.108.208	root	Tue Aug 22 2026 23:19:35 www3 sshd[2221]: Failed password for root from 123.30.108.208 port 2295 ssh2
1787433575	128.241.220.82	helpdesk	Tue Aug 22 2026 23:19:35 www3 sshd[3917]: Failed password for invalid user helpdesk from 128.241.220.82 port 3210 ssh2
1787433575	128.241.220.82	root	Tue Aug 22 2026 23:19:35 www3 sshd[1448]: Failed password for root from 128.241.220.82 port 3117 ssh2

"Per avere una visione chiara e ordinata di TUTTI gli attacchi falliti." I log grezzi sono disordinati e pieni di testo inutile. Abbiamo usato `rex` per estrarre l'IP e l'Username dal testo, e `table + rename` per creare una tabella pulita e ordinata dalla data più recente.

Query 2: Sessioni SSH aperte con successo per "djohnson"

```
index=esercizio "djohnson" ("Accepted password" OR "session
opened")
| rex "uid=(?<uid>[0-9]+)"
| table _time, uid
| rename _time as "Timestamp", uid as "ID Utente"
| sort -_time
```

New Search Save As ▾ Create Table View Close

```
index=esercizio "djohnson" ("Accepted password" OR "session opened")
| rex "uid=(?<uid>[0-9]+)"
| table _time, uid
| rename _time as "Timestamp", uid as "ID Utente"
| sort -_time
```

Cosa fa: Cerca accessi riusciti di djohnson, estrae il suo ID utente (UID).

Time range: All time 🔍 🌟

✓ 2,224 events (before 9/9/26 3:50:09.000 PM) No Event Sampling ▾ Job ▾ ⏏ ⏏ ⏏ ⏏ ⏏ ⏏ Smart Mode ▾

Events Patterns **Statistics (2,224)** Visualization

Show: 20 Per Page ▾ Format ▾ Preview: On < Prev 1 2 3 4 5 6 7 8 ... Next >

Timestamp ▾ ↕	ID Utente ▾ ↕
1787606375	0
1787606375	
1787606375	0
1787606375	
1787606375	0
1787606375	
1787606375	
1787606375	0
1787606375	0
1787606375	

"Per verificare se l'utente specifico 'djohnson' è riuscito ad entrare e quali privilegi ha."

Query 3: Tentativi falliti dall'IP 86.212.199.60

```
index=esercizio "Failed password" 86.212.199.60
| rex "Failed password for (?:invalid user )?(?<user>[a-zA-Z0-9_\-]+)"
| rex "port (?<port>[0-9]+)"
| table _time, user, port
| rename _time as "Timestamp", user as "Username", port as
"Porta"
| sort -_time
```

New Search Save As ▾ Create Table View Close

Time range: All time ▾  

```
index=esercizio "Failed password" 86.212.199.60
| rex "Failed password for (?:invalid user )?(?<user>[a-zA-Z0-9_\-]+)"
| rex "port (?<port>[0-9]+)"
| table _time, user, port
| rename _time as "Timestamp", user as "Username", port as "Porta"
| sort -_time
```

✓ 158 events (before 9/9/26 3:50:32.000 PM) No Event Sampling ▾ Job ▾ || ■ ↻ 📄 ⬇️ 💡 Smart Mode ▾

Events Patterns **Statistics (158)** Visualization

Show: 20 Per Page ▾  Preview: On < Prev 1 2 3 4 5 6 7 8 Next >

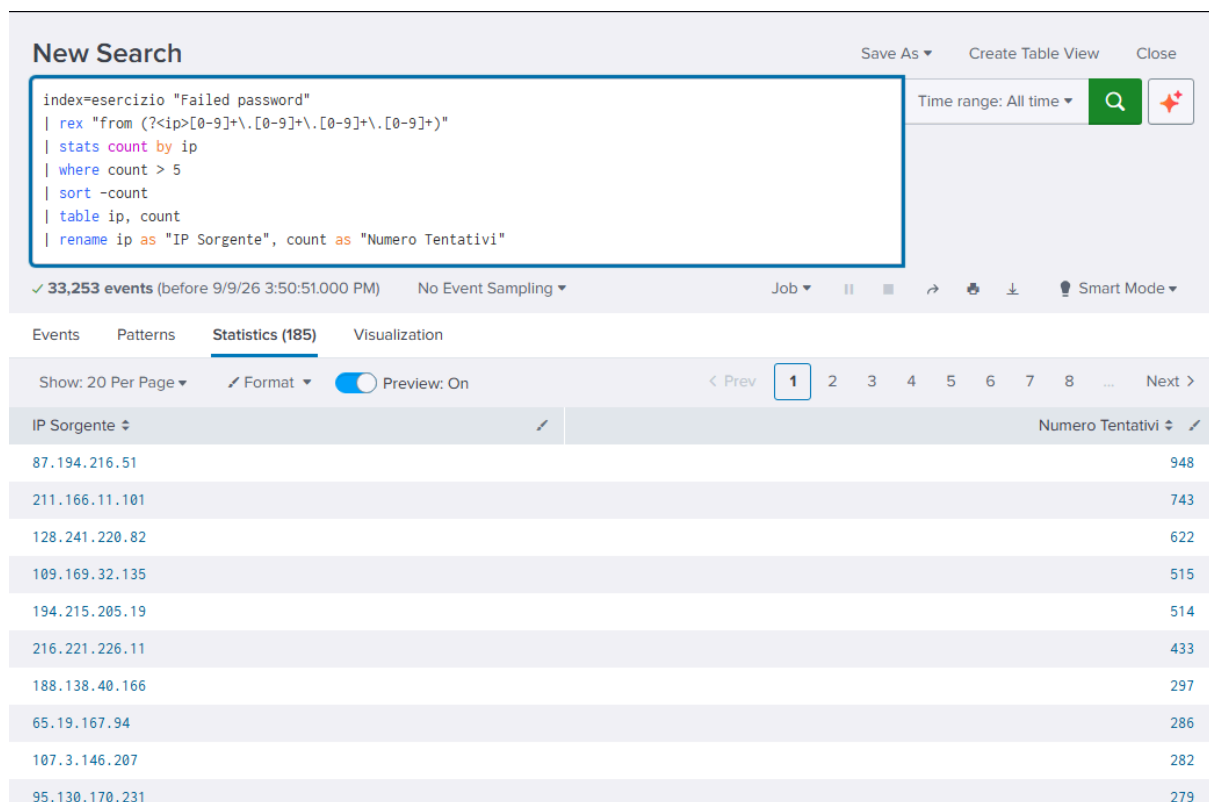
Timestamp ▾ 	Username ▾ 	Porta ▾ 
1787519975	services	1393
1787519975	sync	1695
1787519975	admin	3673
1787519975	nginx	1582
1787519975	whois	1635
1787519975	mailman	4339
1787519975	mailman	1954
1787519975	rdb	2650
1787433575	ncsd	4022
1787433575	games	1763

"Per isolare il comportamento di un singolo sospetto e capire cosa ha tentato."

L'esercizio ci chiedeva di analizzare un IP specifico. Vogliamo vedere quali username ha provato quel preciso IP e quali porte ha usato per attaccare, per capire se era un attacco mirato o generico.

Query 4: Rilevamento attacchi brute force

```
index=esercizio "Failed password"
| rex "from (?<ip>[0-9]+\.[0-9]+\.[0-9]+\.[0-9]+)"
| stats count by ip
| where count > 5
| sort -count
| table ip, count
| rename ip as "IP Sorgente", count as "Numero Tentativi"
```



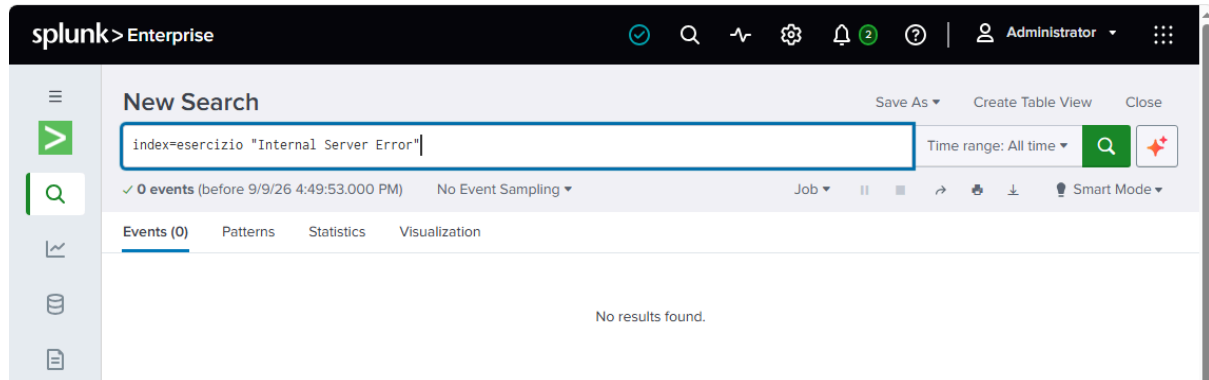
The screenshot shows the Splunk Search interface. At the top, a 'New Search' panel contains the query: `index=esercizio "Failed password"`, `| rex "from (?<ip>[0-9]+\.[0-9]+\.[0-9]+\.[0-9]+)"`, `| stats count by ip`, `| where count > 5`, `| sort -count`, `| table ip, count`, and `| rename ip as "IP Sorgente", count as "Numero Tentativi"`. Below the query panel, it shows '33,253 events (before 9/9/26 3:50:51.000 PM)' and 'No Event Sampling'. The main results area is titled 'Statistics (185)' and shows a table with two columns: 'IP Sorgente' and 'Numero Tentativi'. The table lists 10 IP addresses and their corresponding number of failed password attempts.

IP Sorgente	Numero Tentativi
87.194.216.51	948
211.166.11.101	743
128.241.220.82	622
109.169.32.135	515
194.215.205.19	514
216.221.226.11	433
188.138.40.166	297
65.19.167.94	286
107.3.146.207	282
95.130.170.231	279

"Per identificare chi è il più aggressivo e automatizzare la ricerca degli attaccanti." Non basta sapere che ci sono tentativi falliti; serve capire chi sta facendo da "capo" dell'attacco. Usiamo `stats` per contare i tentativi per ogni IP, `where` per filtrare solo quelli con più di 5 tentativi (soglia di allarme) e `sort` per mettere in cima i colpevoli principali. Serve a creare la lista nera (blacklist) degli IP da bloccare.

Query 5: Ricerca Errori Web

Codice: `index=esercizio "Internal Server Error"`



"Per verificare se ci sono errori critici nel servizio web (HTTP 500)." È una ricerca rapida per capire se il server web ha "crashato" o se ci sono stati tentativi di sfruttamento che hanno generato errori. Se non troviamo nulla, significa che l'attacco si è limitato agli accessi SSH e non ha danneggiato il servizio web.

Conclusioni

Dall'analisi è emerso un attacco brute force coordinato ma nessuna compromissione riuscita